



Analytical Report on the “Shwapno Customer Data Leakage” Incident

Prepared By: Mohammad Shahadat Hossain

Executive Summary

1. Incident Overview

1.1 Organization Profile

1.2 Nature of the Breach

3. Technical Analysis

3.1 Attack Methodology

Phase 1: Initial Compromise

Phase 2: Lateral Movement and Persistence

Phase 3: Data Exfiltration

Phase 4: Ransomware Deployment

Phase 5: Extortion and Data Publication

3.2 Threat Actor Profile

Qilin Ransomware Syndicate

LockBit 5.0

3.3 Compromised Data Categories

4. Impact Assessment

4.1 Customer Impact

4.2 Business Impact

4.3 Severity Assessment

5.1 Technical Vulnerabilities

5.2 Process and Organizational Failures

6. Immediate Defensive Measures

6.1 Customer Protection Actions

6.2 Technical Containment

6.3 Legal and Regulatory Compliance

7. Long-Term Preventive Recommendations

7.1 Technical Security Enhancements

Email Security

Endpoint Protection

Data Protection

Security Monitoring and Detection

Identity and Access Management

Security Awareness and Training

Incident Response

Governance and Compliance



[Third-Party Risk Management](#)

[7.3 Implementation Roadmap](#)

[8. Compliance and Legal Considerations](#)

[8.1 Regulatory Compliance Requirements](#)

[8.2 Liability Management](#)

[9. Key Lessons Learned](#)

[10. Conclusion](#)



Executive Summary

This report provides a comprehensive analysis of the cybersecurity incident affecting Shwapno, Bangladesh's largest supermarket chain. The breach, which occurred in August 2025 but was publicly disclosed in March 2026, resulted in the compromise of approximately 4 million customer records and 410 GB of sensitive corporate data.

Category	Details
Attack Vector	Phishing emails with malicious links targeting employees
Threat Actors	Qilin ransomware syndicate and LockBit 5.0
Initial Breach Date	August 19, 2025, approximately 2:00 PM
Public Disclosure	March 27, 2026 (7 months delay)
Affected Records	~4 million customers (40 lakh registered users)
Data Exfiltrated	410 GB (leaked to dark web on March 17, 2026)
Ransom Demand	\$1.5 million (Tk 18.3 crore) - Not paid



1. Incident Overview

Shwapno, a major retail chain, reportedly experienced a data breach where sensitive customer information was exposed. The leaked data potentially included:

- Customer names
- Phone numbers
- Email addresses
- Purchase history
- Possibly partial payment-related metadata

The breach appears to have originated from weaknesses in backend systems or misconfigured databases, making the data accessible to unauthorized actors.

1.1 Organization Profile

- Company: Shwapno (subsidiary of ACI Limited)
- Industry: Retail/Supermarket Chain
- Scale: Bangladesh's largest supermarket chain
- Operations: 812 outlets across 63 districts
- Customer Base: Over 4 million registered customers

1.2 Nature of the Breach

The incident represents a sophisticated ransomware attack combined with data exfiltration. Attackers gained unauthorized access to Shwapno's customer database and corporate systems through a coordinated phishing campaign, deployed



ransomware to lock critical systems, and subsequently exfiltrated sensitive data when ransom demands were not met.

2. Detailed Timeline of Events

Date	Event	Phase
Pre-August 2025	Reconnaissance and social engineering phase. Attackers sent phishing emails with malicious links to Shwapno employees.	Initial
August 19, 2025 ~2:00 PM	Ransomware deployment. Computers at ACI Logistics Limited head office were locked by Qilin ransomware. Systems encrypted and rendered inaccessible.	Attack
August 19, 2025 (Immediate)	Initial response. MIS team disconnected internet access, inspected devices, removed malware, and implemented emergency security measures.	Response
August 2025	Ransom demand communicated via email. Attackers demanded \$1.5 million with a deadline of December 2025. Threatened data release if demands not met.	Extortion



December 2025	Ransom deadline passed. Shwapno refused to pay. Attackers allegedly regained or maintained control of website and database systems.	Standoff
March 17, 2026	Data leak. Over 410 GB of Shwapno data published on the dark web via LockBit 5.0 portal. Data began circulating on social media platforms and public websites.	Breach
March 27-28, 2026	Public disclosure and legal action. The company publicly confirmed the breach. General Diary filed with Tejgaon Industrial Area Police Station. Investigation transferred to Detective Branch Cyber Unit.	Disclosure
March 30, 2026	Legal notice. Barrister sent legal notice to ACI Limited demanding information on breach, affected customer list, compensation measures, and cybersecurity strengthening within 7 days.	Legal

3. Technical Analysis

3.1 Attack Methodology

Phase 1: Initial Compromise

- Vector: Spear-phishing emails containing malicious links



- Target: Shwapno employees with system access
- Objective: Credential harvesting and initial system access

Phase 2: Lateral Movement and Persistence

- Attackers established persistence in the network
- Conducted reconnaissance of network architecture
- Identified high-value targets (customer database, financial systems)
- Duration: Extended period before ransomware deployment

Phase 3: Data Exfiltration

- Volume: 410 GB of sensitive data extracted
- Method: Likely conducted over extended period to avoid detection
- Timing: Prior to ransomware deployment (insurance against non-payment)

Phase 4: Ransomware Deployment

- Malware: Qilin ransomware variant
- Impact: Systems at ACI Logistics head office locked down
- Timing: August 19, 2025, approximately 2:00 PM
- Effect: Critical business operations disrupted

Phase 5: Extortion and Data Publication



- Platform: LockBit 5.0 dark web portal
- Publication date: March 17, 2026 (after ransom refusal)
- Distribution: Data spread to social media and public websites

3.2 Threat Actor Profile

Qilin Ransomware Syndicate

- Type: Ransomware-as-a-Service (RaaS) operation
- Activity: Known for targeting large organizations globally
- Tactics: Double extortion (encryption + data theft)
- Sophistication: High-level technical capabilities

LockBit 5.0

- Role: Data leak platform and ransomware variant
- Infrastructure: Dark web portal for leaked data distribution
- Pattern: Publishes victim data when ransoms unpaid

3.3 Compromised Data Categories

Data Category	Details
Customer Personal Data	Names, mobile phone numbers, purchase histories (April-May 2025 confirmed, potentially more)



Supplier Information	Company details, individual supplier contacts, contract documents
Financial Records	Daily sales records, bank deposit information, banking contact details
Operational Data	Outlet-wise wastage data, stock loss data, detailed product information, inventory reports, audit reports
HR & Administrative	Employee personal records, HR documents, outlet lists and contact details, internal policies

4. Impact Assessment

4.1 Customer Impact

- **Privacy Breach:** Personal information of 4 million customers publicly exposed
- **Phishing Risk:** Phone numbers enable targeted social engineering attacks
- **Identity Theft:** Biometric-linked phone numbers create elevated risk
- **Financial Fraud:** Banking services increasingly phone-dependent, creating vulnerability
- **Behavioral Profiling:** Purchase histories enable personalized scams and targeted marketing exploitation



4.2 Business Impact

- **Reputational Damage:** Significant loss of customer trust as Bangladesh's largest supermarket chain
- **Legal Liability:** Legal notices filed, potential compensation claims from 4 million customers
- **Operational Disruption:** Systems locked for extended period affecting business operations
- **Competitive Intelligence Loss:** Proprietary sales data, supplier contracts, and operational metrics exposed
- **Remediation Costs:** Forensic investigation, system hardening, legal fees, potential customer compensation
- **Regulatory Scrutiny:** Investigation by Counter Terrorism and Transnational Crime (CTTC) unit

4.3 Severity Assessment

Overall Severity: HIGH

The breach severity is classified as HIGH based on the combination of large-scale customer impact (4 million individuals), sensitive data types exposed, extended dwell time (7+ months), sophisticated threat actors, and the deliberate publication of data following ransom refusal. The delayed disclosure period exacerbated customer risk by preventing timely protective actions.

5. Root Cause Analysis



5.1 Technical Vulnerabilities

1. Insufficient Email Security Controls

Phishing emails successfully delivered to employees, indicating inadequate email filtering and threat detection mechanisms.

2. Lack of Network Segmentation

Attackers achieved lateral movement from initial compromise to critical systems, suggesting insufficient network isolation.

3. Inadequate Data Loss Prevention (DLP)

Exfiltration of 410 GB went undetected, indicating absence of effective DLP monitoring and alerting.

4. Weak Endpoint Protection

Ransomware successfully deployed across multiple systems, suggesting inadequate endpoint detection and response (EDR) capabilities.

5. Insufficient Security Monitoring

Extended attacker presence went undetected (months before ransomware deployment), indicating gaps in Security Information and Event Management (SIEM) and threat hunting.

5.2 Process and Organizational Failures

6. Inadequate Security Awareness Training



Employees fell victim to phishing attacks, demonstrating insufficient cybersecurity education and simulated phishing exercises.

7. Delayed Incident Response

Seven-month delay between breach and public disclosure, legal action filed only after data appeared on dark web.

8. Insufficient Incident Communication

No immediate customer notification despite awareness of breach in August 2025, depriving customers of opportunity to protect themselves.

9. Overreliance on Technical Team Assessment

Management accepted technical team's assurance that data was recovered, failing to verify or engage external expertise promptly.

10. Absence of Comprehensive Backup Strategy

Ransomware successfully disrupted operations, suggesting inadequate offline backup systems and recovery procedures.

6. Immediate Defensive Measures

6.1 Customer Protection Actions

- **Issue Public Warning:** Comprehensive notification to all 4 million affected customers via multiple channels (email, SMS, website, physical outlets)



- **Provide Fraud Protection Guidance:** Educate customers on phishing recognition, suspicious call identification, and protective measures
- **Establish Customer Support Hotline:** Dedicated assistance for breach-related queries and incident reporting
- **Offer Identity Monitoring Services:** Provide complimentary credit monitoring and identity theft protection where available
- **Partner with Mobile Operators:** Coordinate with telecom providers to flag and block fraudulent activities targeting customers.

6.2 Technical Containment

- **Complete Network Isolation:** Immediately isolate all potentially compromised systems.
- **Forensic Preservation:** Preserve system images and logs for investigation before remediation.
- **Credential Reset:** Force password changes for all employee accounts, implement multi-factor authentication.
- **Malware Eradication:** Complete system reimaging with verified clean backups.
- **Third-Party Assessment:** Engage reputable cybersecurity firm for comprehensive security audit.

6.3 Legal and Regulatory Compliance



- **Full Cooperation with Law Enforcement:** Provide all necessary evidence to CTTC and Detective Branch Cyber Unit.
- **Regulatory Notification:** Report to relevant data protection authorities and comply with breach notification requirements.
- **Legal Consultation:** Engage data privacy legal experts to assess liability and compliance obligations.
- **Document Incident Response:** Maintain detailed timeline and actions taken for regulatory and legal proceedings.

7. Long-Term Preventive Recommendations

7.1 Technical Security Enhancements

Email Security

- Deploy advanced email security gateway with AI-powered threat detection
- Implement DMARC, SPF, and DKIM email authentication protocols
- Enable sandboxing for attachment and link analysis
- Deploy URL rewriting and time-of-click protection

Endpoint Protection

- Implement enterprise Endpoint Detection and Response (EDR) solution
- Deploy next-generation antivirus with behavioral analysis



- Enable application whitelisting on critical systems
- Implement full-disk encryption on all endpoints

Network Security Architecture

- Implement Zero Trust Network Architecture (ZTNA)
- Deploy network segmentation with micro-segmentation for critical assets
- Implement next-generation firewall with intrusion prevention system (IPS)
- Deploy network access control (NAC) for device authentication

Data Protection

- Implement Data Loss Prevention (DLP) solution across network, endpoints, and cloud
- Deploy database activity monitoring and encryption
- Implement data classification and handling policies
- Enable encryption for data at rest and in transit
- Implement data minimization - retain only necessary customer information

Security Monitoring and Detection

- Deploy Security Information and Event Management (SIEM) system
- Establish 24/7 Security Operations Center (SOC) or engage Managed Security Service Provider (MSSP)



- Implement User and Entity Behavior Analytics (UEBA)
- Deploy threat intelligence feeds and automated correlation
- Conduct regular threat hunting exercises

Identity and Access Management

- Implement enterprise-wide Multi-Factor Authentication (MFA)
- Deploy Privileged Access Management (PAM) solution
- Implement least privilege access principles
- Conduct quarterly access reviews and recertification
- Implement strong password policies and password managers

Backup and Recovery

- Implement 3-2-1 backup strategy (3 copies, 2 different media, 1 offsite)
- Deploy immutable backup storage to prevent ransomware encryption
- Maintain air-gapped offline backups
- Conduct monthly backup restoration testing
- Document and test disaster recovery procedures quarterly

7.2 Process and Organizational Improvements

Security Awareness and Training



- Mandatory quarterly cybersecurity awareness training for all employees
- Monthly simulated phishing exercises with metrics and feedback
- Role-based security training for IT staff and administrators
- Executive-level cybersecurity briefings
- Security awareness campaigns and regular communications

Incident Response

- Develop comprehensive Incident Response Plan (IRP)
- Establish Incident Response Team with defined roles and responsibilities
- Conduct tabletop exercises and simulations quarterly
- Establish clear escalation procedures and communication protocols
- Retain incident response retainer with specialized cybersecurity firm
- Define breach notification timelines and customer communication templates

Governance and Compliance

- Establish Information Security Governance Committee with executive oversight
- Appoint Chief Information Security Officer (CISO)
- Develop comprehensive Information Security Policy framework
- Implement security metrics and KPI dashboard for board reporting
- Conduct annual third-party security audits and penetration testing



- Align with international standards (ISO 27001, NIST Cybersecurity Framework)

Third-Party Risk Management

- Implement vendor security assessment program
- Require security attestations and certifications from vendors
- Include security requirements in all vendor contracts
- Conduct periodic vendor security reviews
- Limit vendor access to minimum necessary systems and data

7.3 Implementation Roadmap

Priority	Timeline	Key Initiatives
Critical	0-3 months	MFA implementation, EDR deployment, SIEM setup, incident response plan, security awareness training launch, forensic investigation completion
High	3-6 months	Email security gateway, DLP implementation, network segmentation, PAM deployment, backup infrastructure upgrade, SOC establishment



Medium	6-12 months	Zero Trust architecture, UEBA deployment, ISO 27001 certification, advanced threat intelligence, comprehensive vendor risk program
--------	-------------	--

8. Compliance and Legal Considerations

8.1 Regulatory Compliance Requirements

- **Bangladesh Data Protection Obligations:** Comply with Digital Security Act 2018 and relevant data protection regulations
- **Customer Notification:** Provide timely, transparent communication to all affected customers as required by law
- **Regulatory Reporting:** Submit required breach notifications to Bangladesh Telecommunication Regulatory Commission (BTRC) and other relevant authorities
- **Payment Card Industry (PCI) Compliance:** If payment card data was stored, ensure PCI DSS compliance and notify payment card brands

8.2 Liability Management

- Assess potential class action litigation risk
- Review cyber insurance policy coverage and file claims
- Evaluate customer compensation framework



- Document all remediation efforts for liability mitigation

9. Key Lessons Learned

9.1. Human Factor Remains Primary Vulnerability

Phishing attacks continue to be highly effective. Employee security awareness is as critical as technical controls.

9.2. Defense in Depth is Essential

Single-layer security fails. Multiple defensive layers (email filtering, endpoint protection, network segmentation, monitoring) are necessary to detect and contain threats.

9.3. Early Detection is Paramount

The extended attacker dwell time (months) before ransomware deployment demonstrates critical need for continuous monitoring and threat hunting.

9.4. Transparent Communication Protects Customers

The seven-month disclosure delay left customers vulnerable to fraud and identity theft. Immediate notification enables protective actions.

9.5. Incident Response Planning Saves Critical Time

Having pre-established procedures, legal counsel, forensic partners, and communication templates enables faster, more effective response.



9.6. Data Minimization Reduces Risk

Retaining only necessary customer data and implementing retention policies limits exposure in breach scenarios.

9.7. Ransomware Payment Creates Additional Risks

Shwapno's refusal to pay ransom was appropriate. Payment provides no guarantee of data deletion, funds criminal operations, and attracts future attacks.

9.8. Executive Engagement is Critical

Cybersecurity requires board-level attention and adequate resource allocation. Security cannot be delegated solely to IT teams.



10. Conclusion

The Shwapno data breach represents a significant cybersecurity incident with far-reaching implications for customer privacy, business operations, and the broader retail sector in Bangladesh. The attack's sophistication, combined with organizational vulnerabilities, resulted in the compromise of 4 million customer records and extensive corporate data.

This incident underscores the evolving threat landscape where cybercriminals employ double extortion tactics, combining ransomware with data theft to maximize leverage. The seven-month delay between breach occurrence and public disclosure exacerbated customer risk and highlights the critical importance of timely incident response and transparent communication.

Moving forward, Shwapno must implement comprehensive security enhancements spanning technical controls, organizational processes, and governance frameworks. The recommended defensive and preventive measures outlined in this report provide a roadmap for strengthening cybersecurity posture and mitigating similar risks.

The incident serves as a cautionary tale for organizations across all sectors. In an era of increasing cyber threats, robust cybersecurity is not optional—it is a fundamental requirement for protecting customers, maintaining trust, and ensuring business continuity. Organizations must prioritize security investments, foster a security-aware culture, and maintain preparedness for inevitable cyber incidents.